

Báo cáo kiểm thử phần mềm UniDrink

Báo cáo kiểm thử phần mềm UniDrink

Ngày: 30/05/2026

Phiên bản: 0.0.0

Công nghệ: React 19, Vite 6, TypeScript, Supabase, PayOS

Phương pháp: Rà soát mã nguồn, kiểm thử tự động bằng lint/build, và kiểm thử chức năng thủ công trên trình duyệt

1. Mục tiêu kiểm thử

Báo cáo này nhằm xác minh ứng dụng UniDrink hoạt động đúng ở các luồng nghiệp vụ chính, bao gồm:

- Xem menu sản phẩm
- Tìm kiếm, lọc và sắp xếp sản phẩm
- Quản lý giỏ hàng
- Đăng nhập bằng Google
- Đặt hàng và thanh toán
- Tra cứu đơn hàng
- Quản trị hệ thống
- Kiểm tra tích hợp PayOS
- Đánh giá các rủi ro bảo mật liên quan đến Supabase, RLS và API thanh toán

Ngoài ra, báo cáo cũng ghi nhận kết quả kiểm thử tự động để đảm bảo mã nguồn biên dịch và build production không phát sinh lỗi.

2. Phạm vi kiểm thử

Trong phạm vi

- Trang `/`
- Trang `/cart`
- Trang `/checkout`
- Trang `/login`
- Trang `/track`
- Trang `/admin`
- Trang `/admin/dashboard`
- Hook `useCart`
- RPC Supabase
- API `/api/payos-create`
- API `/api/payos-webhook`

- RLS và policy trong `supabase_2_security.sql`

Ngoài phạm vi

- Deploy production thực tế
- Stress test
- Kiểm thử trên nhiều trình duyệt khác nhau

3. Kiểm thử tự động

Hạng mục	Lệnh kiểm thử	Kết quả	Ghi chú
Kiểm tra TypeScript	<code>npm run lint</code>	Pass	Không có lỗi biên dịch TypeScript
Build production	<code>npm run build</code>	Pass	Build thành công trong khoảng 3,4 giây; output nằm trong thư mục <code>dist/</code>

Ghi chú cấu hình: Khi chạy ứng dụng thực tế, cần cấu hình `.env.local` với `VITE_SUPABASE_URL` và `VITE_SUPABASE_ANON_KEY`. Nếu thiếu biến môi trường, ứng dụng sẽ sử dụng dữ liệu demo từ `defaultData` trong `supabase.ts`.

4. Test case chức năng

Cột **Kết quả thực tế** dùng để điền `Pass` hoặc `Fail` sau khi kiểm thử trên `http://localhost:3000` với Supabase đã cấu hình.

Mã TC	Module	Mức độ	Kịch bản kiểm thử	Kết quả mong đợi	Kết quả thực tế
TC-01	Home	Cao	Mở <code>/</code> và chờ trang tải	Hiển thị danh sách sản phẩm, thanh tìm kiếm, lọc danh mục và sắp xếp giá. Nếu Supabase chậm hơn 3 giây lần đầu, hiển thị demo data rồi đồng bộ dữ liệu thật.	-
TC-02	Home	Trung bình	Nhập tên sản phẩm vào ô tìm kiếm	Chỉ hiển thị sản phẩm có tên khớp theo ngôn ngữ VI/EN đang chọn.	-
TC-03	Home	Trung bình	Chọn một danh mục sản phẩm	Chỉ hiển thị sản phẩm thuộc danh mục đã chọn.	-
TC-04	Home	Thấp	Thay đổi chế độ sắp xếp giá	Danh sách sản phẩm chuyển đổi giữa giá tăng dần và giảm dần.	-
TC-05	Header, toàn ứng dụng	Trung bình	Chuyển đổi ngôn ngữ VI/EN trên header	Giao diện đổi ngôn ngữ; tên và mô tả sản phẩm dùng <code>name_en</code> khi chọn EN; ngôn ngữ được lưu vào <code>localStorage</code> với key <code>unicafe_lang</code> .	-
TC-06	ProductCard, useCart	Cao	Thêm sản phẩm còn hàng vào giỏ	Biểu tượng đổi trạng thái; badge giỏ hàng trên header tăng; giỏ hàng được lưu vào <code>localStorage</code> với key <code>unicafe_cart</code> .	-
TC-07	useCart, ProductCard	Trung bình	Thêm cùng một sản phẩm quá 10	Số lượng không vượt quá 10; hiển thị cảnh báo đạt giới hạn.	-

Mã TC	Module	Mức độ	Kịch bản kiểm thử	Kết quả mong đợi	Kết quả thực tế
			lần		
TC-08	ProductCard	Trung bình	Thử thêm sản phẩm có <code>is_available = false</code>	Nút thêm vào giỏ bị disabled; hiển thị trạng thái hết hàng.	-
TC-09	CartPage	Cao	Vào <code>/cart</code> , tăng/giảm số lượng và xóa sản phẩm	Số lượng và tổng tiền cập nhật chính xác; khi xóa toàn bộ, hiển thị trạng thái giỏ trống.	-
TC-10	Checkout	Cao	Vào <code>/checkout</code> khi chưa đăng nhập và giỏ có sản phẩm	Redirect về <code>/login</code> với <code>state.from = '/checkout'</code> .	-
TC-11	Login	Cao	Đăng nhập Google sau khi bị chuyển hướng từ checkout	Sau OAuth redirect về <code>/login</code> , tự chuyển về <code>/checkout</code> ; hiển thị banner yêu cầu đăng nhập để hoàn tất đặt hàng.	-
TC-12	Checkout	Trung bình	Nhập tên không hợp lệ, ví dụ <code>A</code> hoặc <code>123</code> , rồi đặt hàng	Hiển thị lỗi <code>invalidName</code> ; không tạo đơn hàng.	-
TC-13	Checkout	Trung bình	Nhập số điện thoại không hợp lệ, ví dụ <code>123</code> hoặc <code>9912345678</code> , rồi đặt hàng	Hiển thị lỗi <code>invalidPhone</code> .	-
TC-14	utils.normalizePhone	Trung bình	Nhập số điện thoại dạng <code>84912345678</code> hoặc <code>084912345678</code>	Số điện thoại được chuẩn hóa thành <code>0912345678</code> và có thể đặt hàng thành công.	-
TC-15	Checkout, RPC	Cao	Điền form hợp lệ, chọn thanh toán tiền mặt và đặt hàng	Hiển thị màn hình thành công với mã đơn dạng <code>DH00000X</code> ; giỏ hàng được xóa; hiển thị hướng dẫn thanh toán tiền mặt.	-
TC-16	Checkout, PayOS, VietQR	Cao	Chọn thanh toán chuyển khoản và đặt hàng	Tạo đơn thành công; hiển thị QR VietQR và/hoặc modal PayOS; mã đơn và số tiền chính xác.	-
TC-17	Checkout, RPC	Cao	Đăng nhập bằng tài khoản thuộc bảng <code>admins</code> , sau đó vào checkout	Hiển thị khung giới hạn tài khoản admin; nút đặt hàng bị disabled; RPC chặn nếu vẫn gọi.	-
TC-18	Checkout	Trung bình	Truy cập <code>/checkout</code> khi giỏ hàng trống và đã đăng nhập	Redirect về <code>/</code> .	-
TC-19	TrackOrder	Cao	Vào <code>/track</code> khi chưa đăng nhập	Hiển thị màn hình yêu cầu đăng nhập; không hiển thị	-

Mã TC	Module	Mức độ	Kịch bản kiểm thử	Kết quả mong đợi	Kết quả thực tế
				đơn hàng.	
TC-20	TrackOrder, RLS	Cao	Đăng nhập Google và vào <code>/track</code>	Chỉ hiển thị đơn có <code>customer_email</code> trùng email đăng nhập; sắp xếp đơn mới nhất trước.	-
TC-21	TrackOrder	Trung bình	Mở rộng chi tiết một đơn hàng trong danh sách	Load <code>order_items</code> và <code>get_order_logs_by_order_id</code> ; hiển thị địa chỉ, món đã đặt và timeline.	-
TC-22	AdminDashboard, Login	Cao	Tài khoản không thuộc bảng <code>admins</code> truy cập <code>/admin/dashboard</code>	Redirect về <code>/login</code> với <code>notAuthorized: true</code> ; hiển thị thông báo không có quyền.	-
TC-23	AdminDashboard	Cao	Tài khoản thuộc bảng <code>admins</code> truy cập dashboard	Vào được dashboard; thấy danh sách đơn hàng và sản phẩm; có thể đổi trạng thái đơn và <code>is_paid</code> .	-
TC-24	AdminDashboard, RLS	Cao	Cập nhật trạng thái đơn hàng	Cập nhật thành công trên UI và database; tài khoản thường không thể update do RLS.	-
TC-25	App.tsx	Trung bình	Quay về site với URL chứa <code>?code=00</code> hoặc <code>?status=PAID</code>	Giỏ hàng được xóa; query params bị xóa khỏi URL.	-
TC-26	supabase.ts	Thấp	Chạy ứng dụng khi thiếu <code>VITE_SUPABASE_*</code>	Menu hiển thị 6 sản phẩm demo; auth mock; không kết nối database thật.	-

5. Kiểm thử API

Mã API	Kịch bản	Kết quả mong đợi	Đánh giá
API-01	Gửi GET tới <code>/api/payos-create</code>	HTTP 405, <code>{ error: "Method not allowed" }</code>	Pass theo code
API-02	POST <code>/api/payos-create</code> thiếu <code>orderCodeText</code> hoặc <code>totalPrice</code>	HTTP 400	Pass theo code
API-03	POST <code>/api/payos-create</code> khi thiếu biến môi trường PayOS	HTTP 500	Pass chức năng, Fail bảo mật do response làm lộ tên biến môi trường
API-04	POST <code>/api/payos-create</code> với body hợp lệ và đủ biến môi trường	HTTP 200, có <code>checkoutUrl</code>	Cần kiểm thử trên môi trường có PayOS
API-05	Gọi API tạo thanh toán không cần token, truyền số tiền tùy ý	Theo thiết kế hiện tại vẫn tạo link thanh toán	Fail bảo mật nghiêm trọng
API-06	POST <code>/api/payos-webhook</code> với chữ ký sai	HTTP 400, không cập nhật database	Pass theo code
API-07	PayOS gửi webhook hợp lệ với <code>code = 00</code>	Cập nhật <code>is_paid = true</code> , <code>status = processing</code>	Cần kiểm thử với PayOS sandbox
API-08	Rà soát <code>SERVICE_ROLE_KEY</code> trong frontend bundle	Không xuất hiện trong client bundle	Pass

6. Kiểm thử bảo mật

Mã	Hạng mục	Kết quả	Ghi chú
SEC-01	RLS đối với <code>order_items</code> và <code>order_logs</code>	Fail nghiêm trọng	Policy chỉ kiểm tra đơn tồn tại, chưa kiểm tra quyền sở hữu. Người dùng đăng nhập nếu biết <code>order_id</code> UUID có thể đọc chi tiết đơn hàng của người khác qua select hoặc RPC <code>get_order_logs_by_order_id</code> .
SEC-02	API <code>/api/payos-create</code> không xác thực	Fail nghiêm trọng	Bất kỳ request nào cũng có thể tạo link thanh toán với số tiền tùy ý.
SEC-03	<code>VITE_SUPABASE_ANON_KEY</code> trên client	Fail gián tiếp	Theo thiết kế Supabase, anon key an toàn nếu RLS đúng. Tuy nhiên, RLS hiện có lỗ hổng ở SEC-01.
SEC-04	Thông tin ngân hàng trên client	Cảnh báo	<code>VITE_BANK_*</code> hiển thị ở checkout để tạo VietQR. Code hiện có fallback cứng khi thiếu env.
SEC-05	Admin guard	Pass	Có kiểm tra frontend, RPC <code>check_is_admin</code> và RLS <code>private.is_admin()</code> .
SEC-06	Email đặt hàng khớp session	Pass	RPC <code>create_order_with_items</code> kiểm tra email khớp JWT.
SEC-07	Chống spam đơn pending	Pass theo code	RPC có blacklist khi vượt <code>spam_order_limit</code> .
SEC-08	Không commit file <code>.env</code>	Pass	<code>.gitignore</code> có rule <code>.env*</code> .

7. Phát hiện khác

- Hàm `get_order_by_code` có trong SQL nhưng chưa được gọi từ frontend. README mô tả chức năng tra cứu bằng mã đơn, trong khi trang `/track` hiện chỉ hiển thị đơn theo email đã đăng nhập.
- Khi Supabase cold-start, ứng dụng có thể hiển thị tạm 6 sản phẩm demo rồi mới đồng bộ dữ liệu thật. Cần ghi chú rõ khi trình bày hoặc demo.
- `DesktopModeWarning` chỉ hiển thị trên mobile khi bật chế độ desktop site, không ảnh hưởng đến chức năng chính.

8. Tổng kết

Nhóm kiểm thử	Kết quả
Kiểm thử tự động	2/2 Pass
Test case chức năng	26 test case cần kiểm thử thủ công và diễn kết quả thực tế
API	Logic cơ bản đúng; phát hiện 2 lỗ hổng bảo mật nghiêm trọng
Bảo mật	2 Fail nghiêm trọng, 1 cảnh báo, các hạng mục còn lại Pass theo code

Đánh giá chung: Ứng dụng đáp ứng tốt các chức năng chính ở mức mã nguồn và build. Tuy nhiên, chưa đạt yêu cầu bảo mật để triển khai production công khai. Cần ưu tiên xử lý các lỗ hổng liên quan đến RLS và API tạo thanh toán trước khi deploy.

9. Đề xuất ưu tiên sửa

- Sửa RLS cho `order_items` và `order_logs` để chỉ cho phép đọc khi đơn hàng thuộc email của người dùng hiện tại hoặc người dùng là admin.
- Bảo vệ `/api/payos-create` bằng xác thực session.
- Không nhận `totalPrice` từ client làm nguồn tin cậy; cần lấy tổng tiền từ database theo `order_code` hoặc order id.
- Không trả tên biến môi trường trong response lỗi API.

5. Xóa fallback số tài khoản ngân hàng cứng trong `Checkout.tsx`.

10. Kết luận

UniDrink có nền tảng chức năng ổn định, build thành công và luồng nghiệp vụ chính đã được xác định rõ để kiểm thử. Trước khi triển khai công khai, cần hoàn tất kiểm thử thủ công 26 test case chức năng và khắc phục các vấn đề bảo mật nghiêm trọng đã ghi nhận.